

Table of Contents

Security Event Investigation and Threat Hunting Using Splunk Enterprise.....	3
1. Executive Summary	3
2. Scope.....	3
3. Data Sources	4
Web Traffic Logs	4
Firewall Logs	4
SIEM Platform.....	5
4. Methodology	5
Phase 1: Data Exploration and Source Identification.....	5
Phase 2: Web Traffic Analysis	5
Phase 3: Traffic Trend Analysis	6
Phase 4: User-Agent and Client Profiling.....	6
Phase 5: Threat Hunting and Detection	6
Phase 6: Post-Exploitation Investigation.....	7
Phase 7: Network Correlation and Command-and-Control Analysis	7
Phase 8: Attack Chain Reconstruction.....	7
5. Figure Explanations.....	7
Figure 1 – Splunk Dashboard Overview	7
Figure 2 – Sourcetype Identification	8
Figure 3 – Web Traffic Event Review	9
Figure 4 – Event Field Analysis	9
Figure (5-7) – Daily Traffic Trend Analysis	10
Figure 8 – User-Agent Analysis	11
Figure 9 – Client IP Analysis	12
Figure 10 – Request Path Analysis	13
Figure (11-13) – Automated Traffic Detection	14
Figure 14 – Sensitive Resource Enumeration.....	16

Figure 15 – Directory Traversal Activity.....	17
Figure 16 – SQL Injection Activity	17
Security Significance	19
Security Significance	19
Figure 19 – Web Shell Activity Detection	20
Security Significance	20
Risk Assessment	21
6. Findings	22
8. Attack Chain Analysis	26
Stage 1: Reconnaissance and Enumeration	27
Stage 2: Vulnerability Discovery and Exploitation Attempts	27
Stage 3: Sensitive File Access Attempts.....	27
Stage 4: Directory Traversal Activity	28
Stage 5: Web Shell Execution and Remote Command Execution	28
Stage 6: Payload Deployment and Execution	28
Stage 7: Command-and-Control Communications	29
Attack Chain Summary	29
9. Conclusion	30
10. Recommendations	30
11. Skills Demonstrated	32
Security Operations & Threat Hunting.....	32
SIEM & Log Analysis	32
Threat Detection.....	32
Cybersecurity Frameworks.....	32
Analytical Skills	32

Security Event Investigation and Threat Hunting Using Splunk Enterprise

1. Executive Summary

This investigation was conducted using Splunk Enterprise to analyze web server and firewall logs for indicators of malicious activity within a web application environment. The objective was to identify suspicious behavior, investigate potential attack attempts, and reconstruct the attack lifecycle through log correlation and threat hunting techniques.

Analysis of over 17,000 web traffic events identified multiple indicators of compromise, including automated reconnaissance, sensitive resource enumeration, SQL injection attempts, directory traversal attacks, web shell activity, execution of a suspicious binary, and outbound command-and-control (C2) communications. User-Agent analysis revealed the use of automated attack tools such as SQLMap, Havij, curl, wget, zgrab, and Python Requests.

The investigation identified a likely attack progression beginning with reconnaissance and vulnerability discovery, followed by exploitation attempts, remote command execution, malware deployment, and communication with external infrastructure. Findings were correlated across web traffic and firewall logs and mapped to the MITRE ATT&CK framework to better understand attacker tactics, techniques, and procedures (TTPs).

The results demonstrate the value of SIEM technologies for threat detection, incident investigation, and attack chain reconstruction within enterprise environments.

2. Scope

The scope of this investigation was limited to the analysis of web server and firewall logs collected within Splunk Enterprise. The objective was to identify indicators of malicious activity, investigate potential exploitation attempts, and determine whether evidence of compromise existed within the environment.

The assessment included:

- Analysis of HTTP web traffic events
- Identification of suspicious client IP addresses
- Review of User-Agent activity
- Detection of SQL injection attempts
- Detection of directory traversal attacks
- Identification of sensitive resource enumeration

- Investigation of web shell activity
- Analysis of suspicious payload execution
- Correlation of firewall logs with web traffic events
- Identification of potential command-and-control communications

The investigation focused exclusively on available log data and did not include host-based forensic analysis, malware reverse engineering, or vulnerability validation on live systems.

3. Data Sources

The investigation utilized data collected and indexed within Splunk Enterprise. Analysis was performed using the following log sources:

Web Traffic Logs

Index: main

Sourcetype: web_traffic

Source: access.csv

The web traffic logs contained HTTP request information including:

- Client IP addresses
- Request methods (GET, POST)
- Request paths and parameters
- HTTP response status codes
- User-Agent strings
- Request timestamps
- Referrer information

These logs were used to identify reconnaissance activity, exploitation attempts, web shell interactions, and suspicious application requests.

Firewall Logs

Sourcetype: firewall_logs

The firewall logs contained network communication events including:

- Source IP addresses
- Destination IP addresses
- Network protocols
- Destination ports

- Connection actions (Allowed/Blocked)
- Security event classifications

These logs were used to identify outbound communications, correlate attacker infrastructure, and investigate potential command-and-control (C2) activity associated with the suspected compromise.

SIEM Platform

Platform: Splunk Enterprise

Splunk Enterprise was utilized to:

- Aggregate log data
- Perform event searches
- Develop SPL queries
- Analyze traffic patterns
- Correlate security events
- Visualize activity trends
- Conduct threat hunting and incident investigation

4. Methodology

The investigation was conducted using Splunk Enterprise to analyze web server and firewall logs for indicators of malicious activity. A structured threat hunting methodology was employed to identify suspicious behavior, investigate attack patterns, and reconstruct the attack chain.

Phase 1: Data Exploration and Source Identification

Initial searches were performed against the main index to identify available data sources and understand the structure of the collected logs. Analysis revealed two primary sourcetypes:

- web_traffic
- firewall_logs

The web_traffic dataset was selected as the primary source for investigating web application attacks, while firewall logs were used to validate network communications and identify potential command-and-control activity.

Phase 2: Web Traffic Analysis

Web traffic logs were filtered using the web_traffic sourcetype to isolate HTTP requests. Event records were reviewed to identify relevant fields, including:

- Client IP addresses
- Request methods
- Request paths
- HTTP status codes
- User-Agent strings
- Timestamps

These fields provided the foundation for identifying suspicious activity and attacker behavior.

Phase 3: Traffic Trend Analysis

Time-based analysis was performed using Splunk's timechart command to visualize daily web traffic volume. Event counts were reviewed to identify unusual spikes in activity and prioritize periods for further investigation.

Phase 4: User-Agent and Client Profiling

User-Agent analysis was conducted to distinguish legitimate browser traffic from automated tools. Requests generated by tools such as SQLMap, Havij, curl, wget, zgrab, Go-http-client, and Python Requests were identified and analyzed to determine attacker intent and techniques.

Client IP analysis was performed to identify sources responsible for suspicious activity and measure their contribution to overall traffic volume.

Phase 5: Threat Hunting and Detection

Targeted searches were developed to identify indicators of common web application attacks, including:

- SQL Injection attempts
- Directory Traversal attacks
- Sensitive file enumeration
- Backup file discovery
- Web shell activity
- Automated scanning behavior

Specific attention was given to requests targeting sensitive resources such as:

- .env

- .git/config
- phpinfo.php
- logs.tar.gz

as well as attack payloads associated with SQL injection and file disclosure vulnerabilities.

Phase 6: Post-Exploitation Investigation

Additional analysis was conducted to identify evidence of successful compromise and post-exploitation activity. Requests involving command execution and suspicious binaries were reviewed to determine whether attackers had gained the ability to execute arbitrary commands on the target system.

Web shell activity and execution of the bunnylock.bin payload were investigated as potential indicators of malware deployment and system compromise.

Phase 7: Network Correlation and Command-and-Control Analysis

Firewall logs were correlated with web traffic events to identify outbound communications associated with the suspected attacker. Network connections were analyzed to determine whether compromised hosts were communicating with external infrastructure.

Special attention was given to connections categorized as C2_CONTACT, which indicated potential command-and-control communications.

Phase 8: Attack Chain Reconstruction

Findings from web traffic analysis, user-agent profiling, exploitation attempts, web shell activity, and firewall logs were correlated to reconstruct the attack lifecycle. The observed activity was mapped to the MITRE ATT&CK framework to identify attacker tactics, techniques, and procedures (TTPs).

This process enabled the identification of a likely attack progression from reconnaissance and vulnerability probing to exploitation, post-exploitation activity, and command-and-control communications.

5. Figure Explanations

Figure 1 – Splunk Dashboard Overview

The Splunk Enterprise dashboard was accessed to manage searches, reports, and visualizations used throughout the investigation.

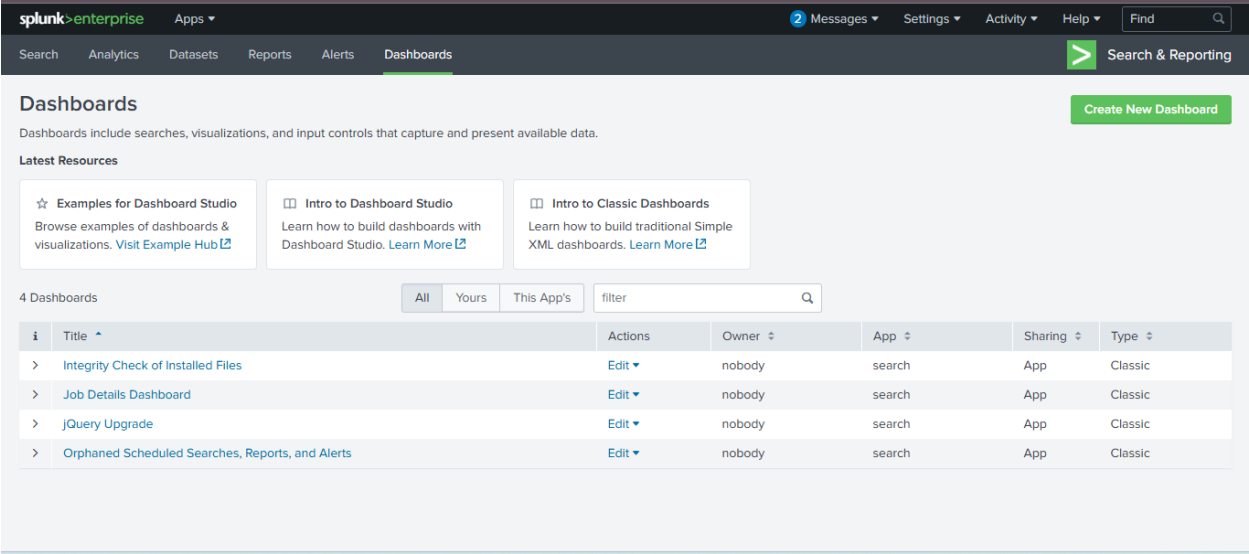


Figure 1: Splunk Dashboard Overview

Figure 2 – Sourcetype Identification

A search of the main index identified two primary data sources:

- web_traffic
- firewall_logs

The web_traffic dataset accounted for approximately 91.6% of all events and was selected for further investigation.

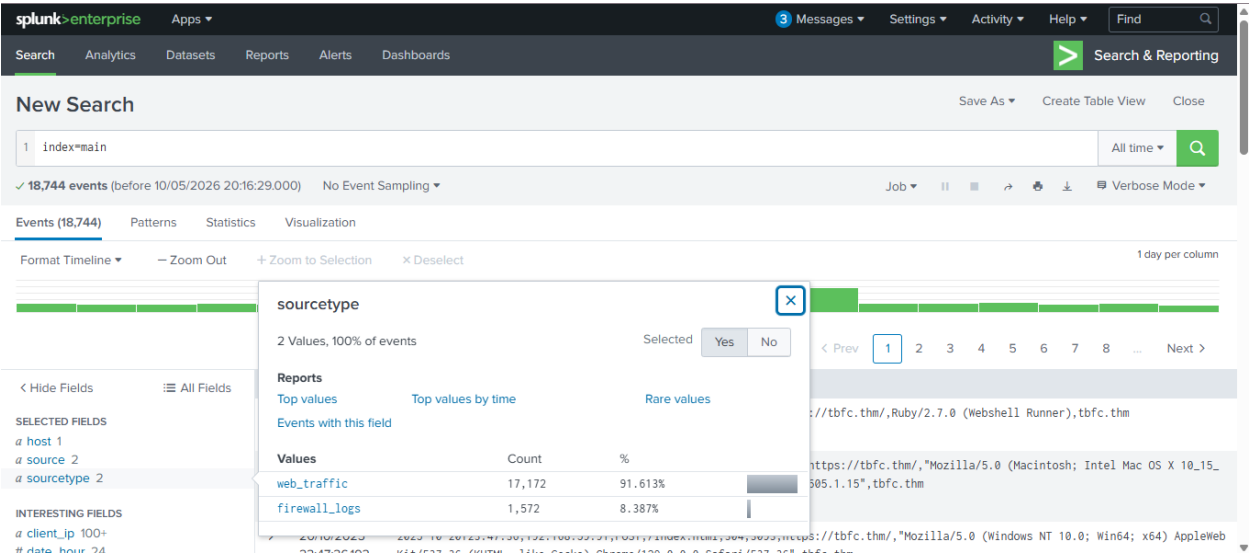


Figure 2: Sourcetype Identification

Figure 3 – Web Traffic Event Review

Filtering for sourcetype=web_traffic isolated over 17,000 HTTP events for analysis. Event records contained:

- Client IP addresses
- Request methods
- Requested resources
- HTTP status codes
- User-agent strings

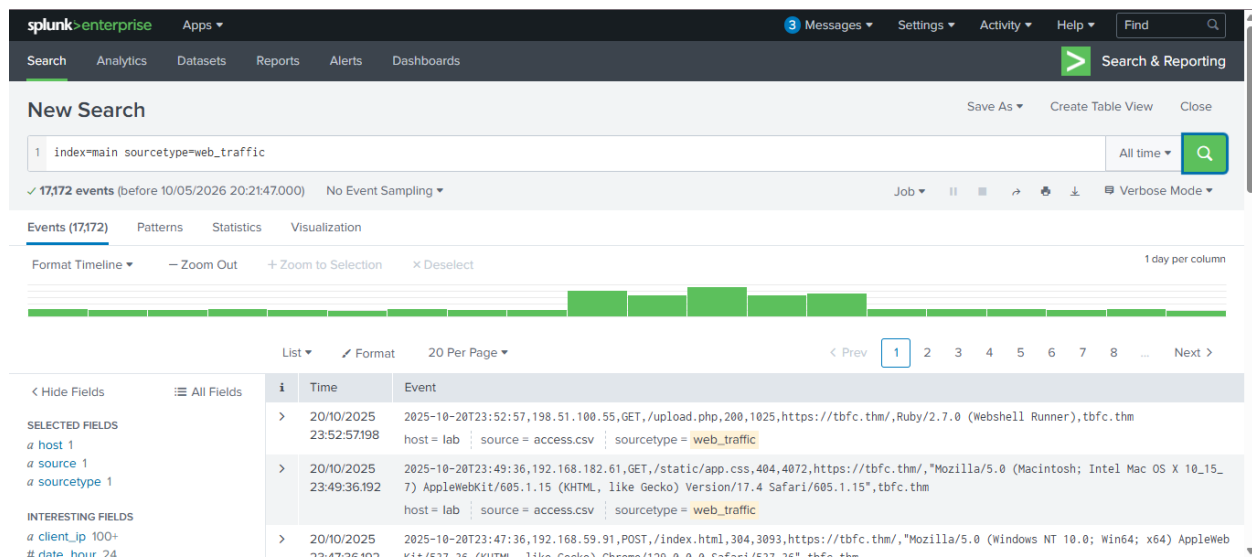


Figure 3: Web Traffic Event Review

Figure 4 – Event Field Analysis

Detailed event inspection revealed key fields including:

- client_ip
- method
- path
- status
- user_agent

< Hide Fields All Fields List ▼ Format 20 Per Page ▼

< Prev 1 2 3 4 5 6 7 8 ... Next >

date_minute 60
date_month 1
date_second 10
date_wday 7
date_year 1
date_zone 1
domain 1
index 1
linecount 1
method 2
path 23
punct 88
referer 1
size_bytes 100+
splunk_server 1
status 7
time 100+
timeendpos 1
timestartpos 1
user_agent 11

+ Extract New Fields

i Time Event

23:42:07:198

Event Actions ▼

Type	Field	Value	Actions
Selected	host ▼	lab	▼
	source ▼	access.csv	▼
	sourcetype ▼	web_traffic	▼
Event	client_ip ▼	198.51.100.55	▼
	domain ▼	tbfct.htm	▼
	method ▼	POST	▼
	path ▼	/item.php?id=1	▼
	size_bytes ▼	2851	▼
	status ▼	500	▼
	time ▼	2025-10-20T23:42:07	▼
	user_agent ▼	sqlmap/1.7.9#stable (http://sqlmap.org)	▼
Time ⌚	_time ▼	2025-10-20T23:42:07:198+00:00	
Default	index ▼	main	▼
	linecount ▼	1	▼
	punct ▼	--::--::--/?=&...&_#_[/],.	▼
	splunk_server ▼	ip-10-10-40-195	▼

Figure 4: Event Field Analysis

These fields were used throughout the investigation to identify suspicious activity.

Figure (5-7) – Daily Traffic Trend Analysis

Time-based analysis using Splunk's timechart command revealed significant spikes in web traffic activity.

New Search

Save As Create Table View Close

1 index=main sourcetype=web_traffic | timechart span=1d count

All time

✓ 17,172 events (before 10/05/2026 20:27:23.000) No Event Sampling

Job

||

Verbose Mode

Events (17,172) Patterns **Statistics (20)** Visualization

100 Per Page

Format

Preview

_time	count
2025-10-01	595
2025-10-02	479
2025-10-03	521
2025-10-04	567
2025-10-05	484
2025-10-06	444
2025-10-07	566
2025-10-08	492
2025-10-09	496
2025-10-10	2012
2025-10-11	1637

Figure 5: Daily Traffic Trend Analysis

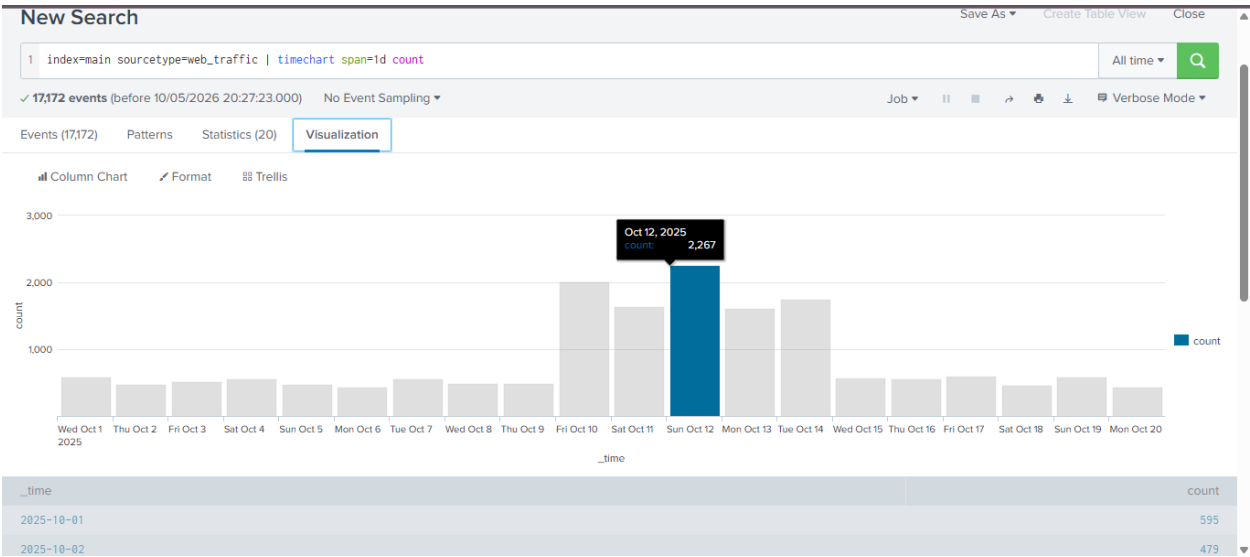


Figure 6:Daily Traffic Trend Analysis(2)

A notable increase was observed between October 10 and October 14, with October 12 producing the highest event volume.

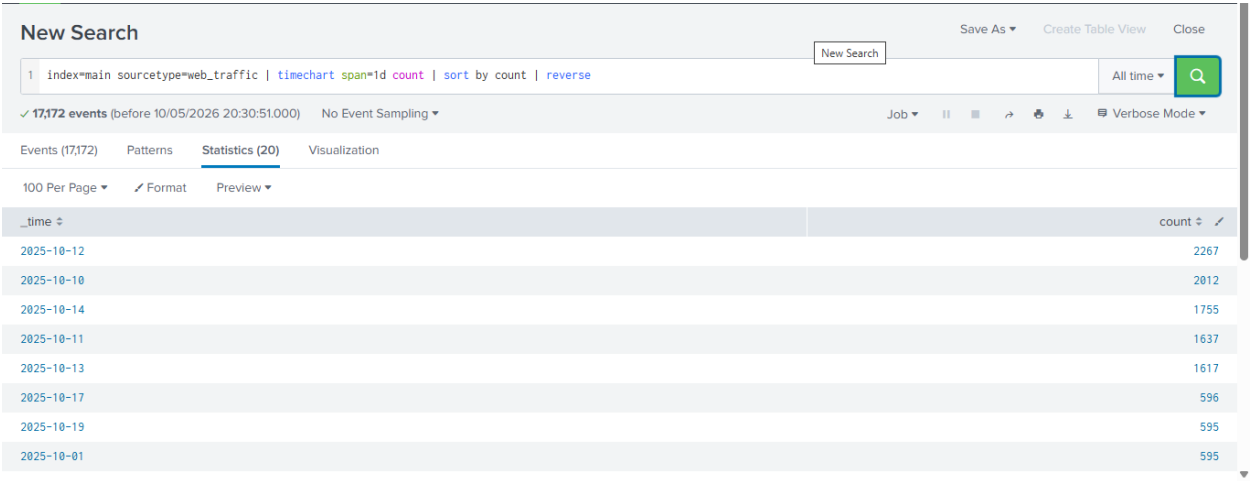


Figure 7:Daily Web Traffic Volume Analysis (Sorted by Event Count)

The results were sorted in descending order using the reverse command to identify dates with the highest web traffic volume, enabling prioritization of periods that may contain suspicious or malicious activity.

Figure 8 – User-Agent Analysis

Analysis of user-agent values identified both legitimate browsers and automated tools.

Suspicious user agents included:

- sqlmap
- Havij
- curl
- wget
- zgrab
- Go-http-client

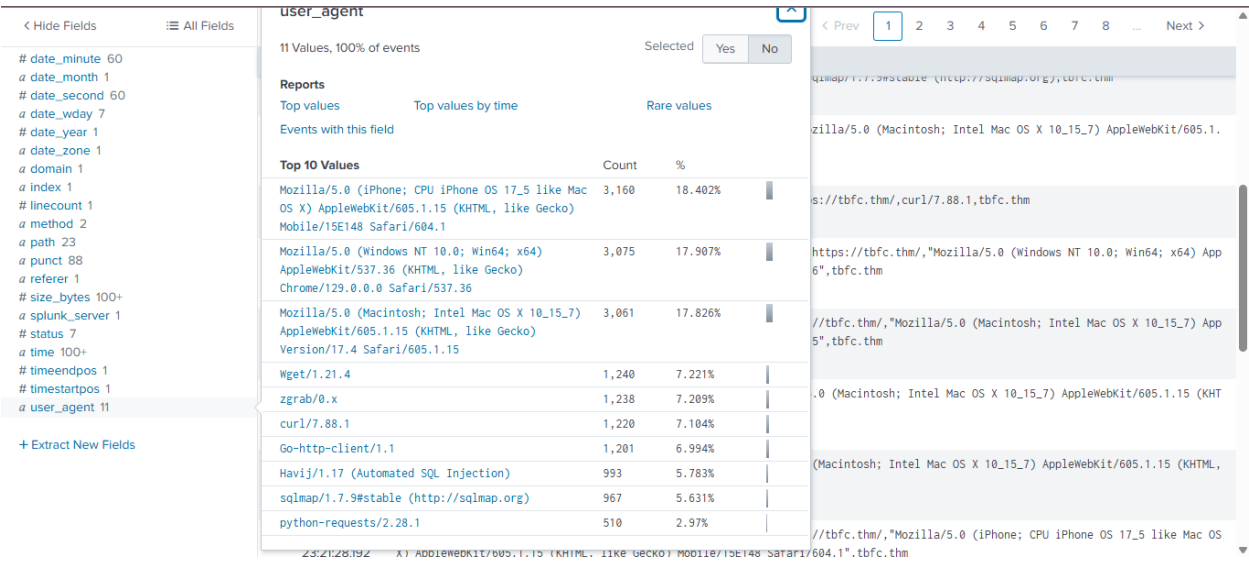


Figure 8:User-Agent Analysis

The presence of these tools suggested automated reconnaissance and exploitation activity.

Figure 9 – Client IP Analysis

Client IP analysis identified a single external address:

198.51.100.55

This IP generated approximately 45.8% of all observed traffic and became the primary subject of investigation.

Frequently requested resources included:

- 13

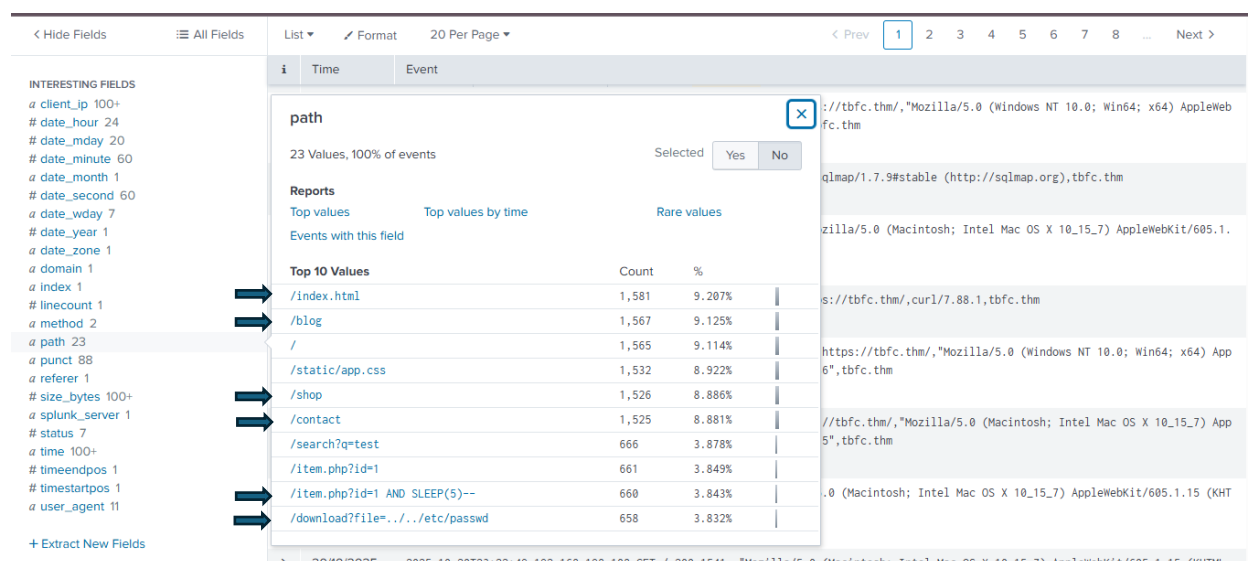


Figure 10: Request Path Analysis

More concerning requests included:

- /item.php?id=1 AND SLEEP(5)—

The request contained a time-based SQL injection payload designed to determine whether user-supplied input was being processed by the backend database. The use of the SLEEP() function is commonly associated with automated SQL injection testing tools such as SQLMap and Havij.

- /download?file=../../etc/passwd

The observed SQL injection and directory traversal payloads indicate active attempts to exploit web application vulnerabilities as part of a broader attack sequence that progressed from reconnaissance to post-exploitation activity.

Figure (11-13) – Automated Traffic Detection

Filtering out legitimate browser user agents revealed that the majority of suspicious requests originated from the same external IP address.

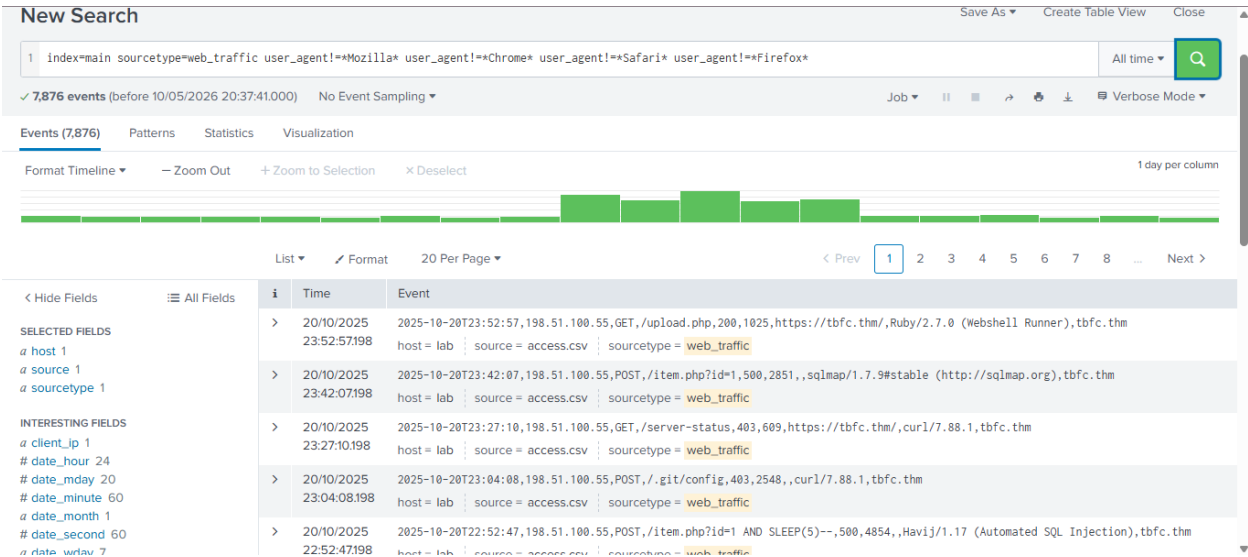


Figure 11:Automated Traffic Detection

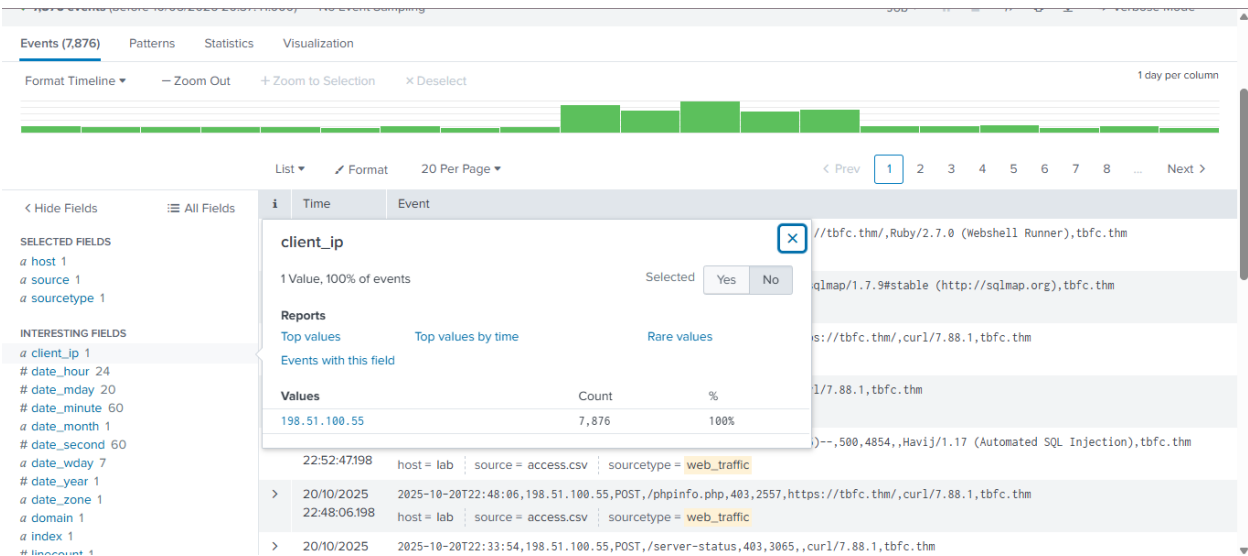


Figure 12:Automated Traffic Detection(2)

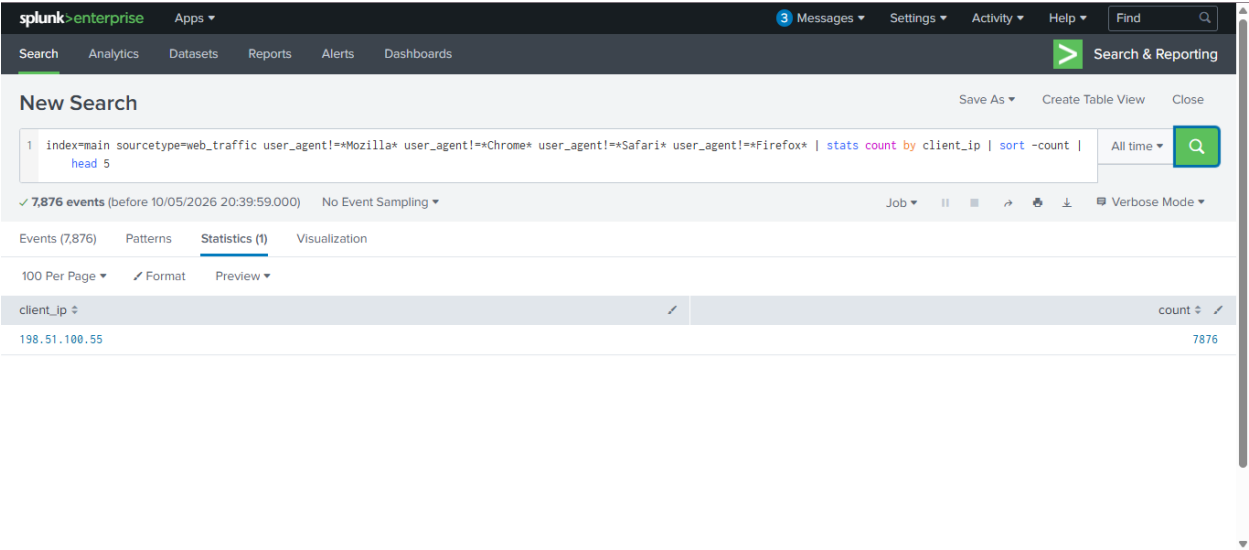


Figure 13:Automated Traffic Detection(3)

This behavior was consistent with automated scanning and attack tooling.

Figure 14 – Sensitive Resource Enumeration

The attacker attempted to access:

- /.env
- /.git/config
- /phpinfo.php

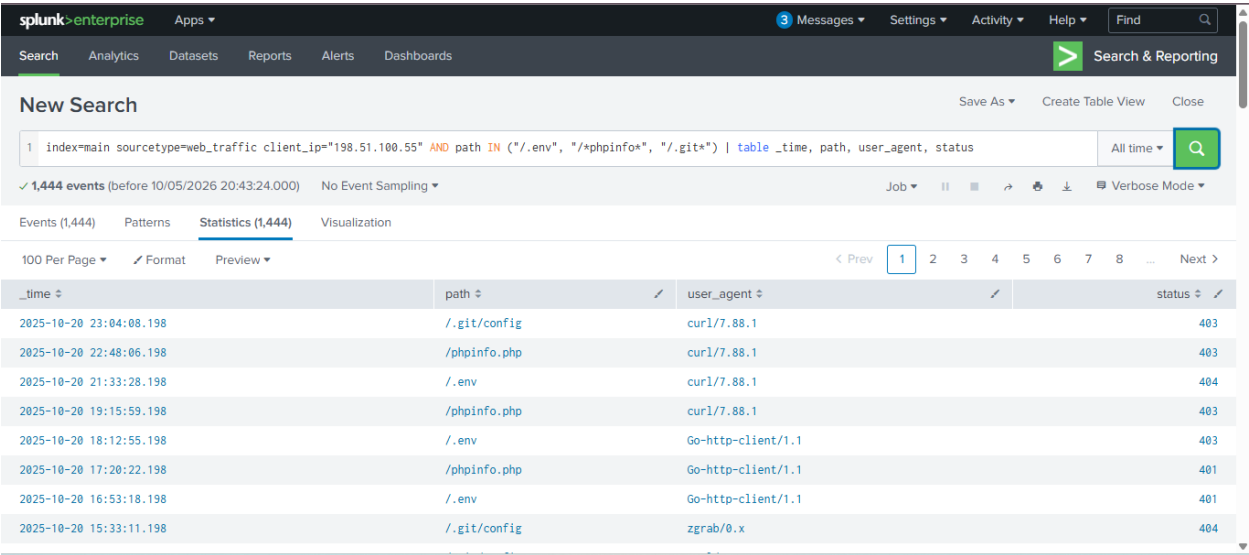


Figure 14:Sensitive Resource Enumeration

These resources commonly contain sensitive configuration information and are frequently targeted during reconnaissance activities.

Figure 15 – Directory Traversal Activity

Requests attempting to access:

/download?file=../../etc/passwd

were identified.



Figure 15:Directory Traversal Activity

This pattern is a well-known directory traversal technique used to access sensitive operating system files.

Figure 16 – SQL Injection Activity

Multiple requests contained payloads such as:

/item.php?id=1 AND SLEEP(5)--

and

/search.php?q=test'%20AND%20SLEEP(5)--

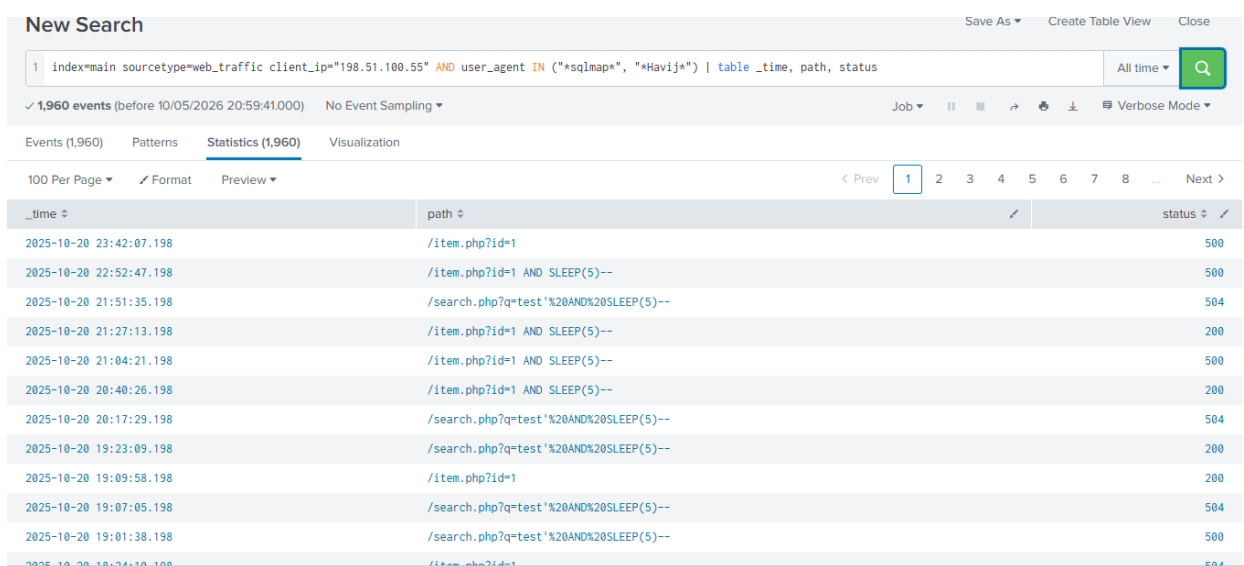


Figure 16:SQL Injection Activity

These payloads are consistent with time-based SQL injection testing commonly performed by automated tools such as SQLMap and Havij.

Figure 17 – SQL Injection Tool Identification

Analysis of the User-Agent field revealed the use of automated SQL injection tools, specifically SQLMap and Havij. The logs show 993 requests originating from Havij and 967 requests originating from SQLMap. The presence of these tools indicates deliberate attempts to identify and exploit SQL injection vulnerabilities within the web application.

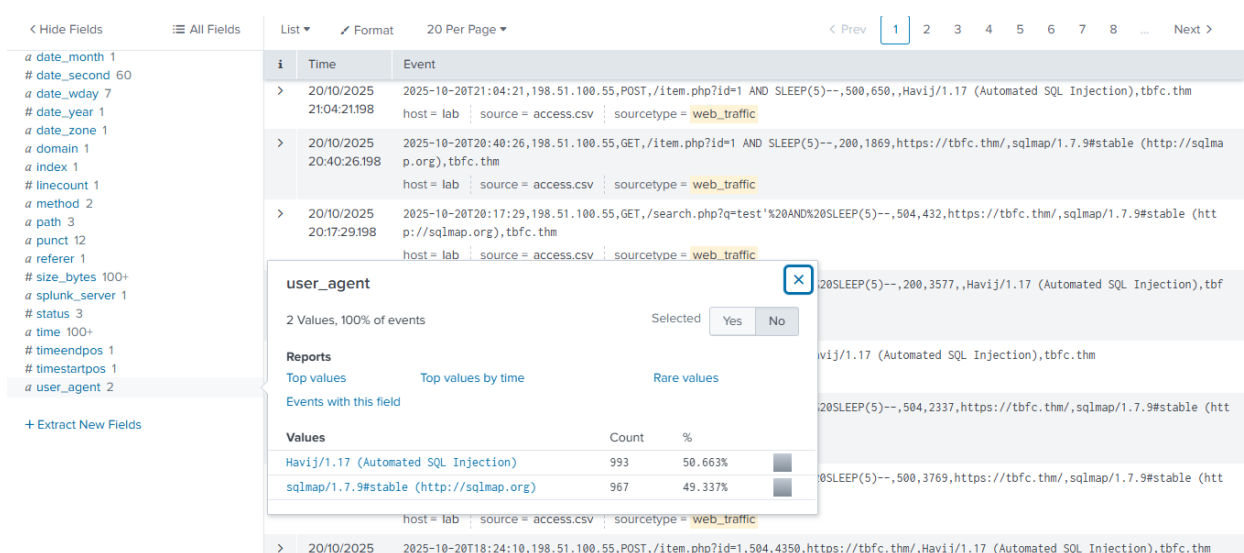


Figure 17:SQL Injection Tool Identification

Security Significance

The use of automated SQL injection frameworks demonstrates active exploitation activity rather than normal web browsing behavior. Attackers commonly leverage these tools to automate payload generation, vulnerability testing, database enumeration, and data extraction.

Figure 18 – Sensitive Archive Enumeration

The investigation identified repeated requests targeting compressed archive files, including:

/logs.tar.gz

Requests originated from automated tools such as:

- curl
- wget
- zgrab
- Go-http-client

New Search

Save As>Create table viewClose

1 index=main sourcetype=web_traffic client_ip="198.51.100.55" AND path IN ("*backup.zip*", "*logs.tar.gz*") | table _time path, user_agent

All time

Q

✓ 347 events (before 10/05/2026 21:09:11.000) No Event SamplingJobPauseRefreshDownloadVerbose Mode

Events (347)PatternsStatistics (347)Visualization

100 Per PageFormatPreview< Prev1234Next >

_time	path	user_agent
2025-10-20 21:41:04.198	/logs.tar.gz	zgrab/0.x
2025-10-20 14:53:46.198	/logs.tar.gz	Wget/1.21.4
2025-10-20 14:12:21.198	/logs.tar.gz	Wget/1.21.4
2025-10-20 11:02:52.198	/logs.tar.gz	zgrab/0.x
2025-10-20 09:32:28.198	/logs.tar.gz	curl/7.88.1
2025-10-20 03:20:55.198	/logs.tar.gz	zgrab/0.x
2025-10-20 02:33:42.198	/logs.tar.gz	curl/7.88.1
2025-10-20 01:30:46.198	/logs.tar.gz	Go-http-client/1.1
2025-10-19 21:54:18.198	/logs.tar.gz	zgrab/0.x
2025-10-19 18:40:50.198	/logs.tar.gz	zgrab/0.x
2025-10-19 15:37:06.198	/logs.tar.gz	curl/7.88.1
2025-10-19 15:33:30.198	/logs.tar.gz	Wget/1.21.4

Figure 18:Sensitive Archive Enumeration

Security Significance

Attackers frequently search for backup archives and log files because they may contain:

- Application source code
- Credentials

- Database connection strings
- Sensitive operational information

Repeated access attempts suggest reconnaissance activity designed to locate exposed backup files.

Figure 19 – Web Shell Activity Detection

Multiple requests targeted a web shell endpoint:

- /shell.php?cmd=whoami
- /shell.php?cmd=chmod+x+bunnylock.bin
- /shell.php?cmd=./bunnylock.bin

Observed User-Agent values included:

- Ruby/2.7.0 (Webshell Runner)
- python-requests
- zgrab
- wget

_time	path	user_agent	status
2025-10-20 19:32:47.198	/shell.php?cmd=whoami	Ruby/2.7.0 (Webshell Runner)	500
2025-10-20 16:31:24.198	/bunnylock.bin	zgrab/0.x	200
2025-10-20 16:29:12.198	/shell.php?cmd=chmod%20+x%20bunnylock.bin	python-requests/2.28.1	500
2025-10-20 15:15:30.198	/bunnylock.bin	Wget/1.21.4	403
2025-10-20 13:18:54.198	/bunnylock.bin	zgrab/0.x	200
2025-10-20 12:58:47.198	/shell.php?cmd=./bunnylock.bin	Ruby/2.7.0 (Webshell Runner)	200
2025-10-20 11:46:32.198	/shell.php?cmd=./bunnylock.bin	Ruby/2.7.0 (Webshell Runner)	500
2025-10-20 11:31:28.198	/bunnylock.bin	Wget/1.21.4	200
2025-10-20 10:52:07.198	/shell.php?cmd=whoami	Ruby/2.7.0 (Webshell Runner)	200
2025-10-20 10:28:57.198	/shell.php?cmd=chmod%20+x%20bunnylock.bin	python-requests/2.28.1	403
2025-10-20 09:20:21.198	/shell.php?cmd=chmod%20+x%20bunnylock.bin	python-requests/2.28.1	500

Figure 19: Web Shell Activity Detection

Security Significance

These requests strongly indicate post-exploitation activity.

The attacker appears to:

- 1. Verify command execution using whoami.
- 2. Modify file permissions using chmod.
- 3. Execute a payload named bunnylock.bin.

The observed behavior is consistent with remote command execution and malware deployment techniques commonly used after successful compromise.

Risk Assessment

Critical

Figure 20 – Command-and-Control (C2) Communications

Firewall logs revealed repeated outbound TCP connections between:

Source IP:
10.10.1.5

Destination IP:
198.51.100.55

Destination Port:
8080

Reason:
C2_CONTACT

New Search

Save As>Create Table View*Close

1 sourceType=firewall_logs src_ip="10.10.1.5" AND dest_ip="198.51.100.55" AND action="ALLOWED" | table _time, action, protocol, src_ip, dest_ip, dest_port, reasonAll time

285 events (before 10/05/2026 21:26:20.000)No Event SamplingJob|||+*+Verbose Mode

Events (285)PatternsStatistics (285)Visualization

100 Per PageFormatPreview

_time	action	protocol	src_ip	dest_ip	dest_port	reason
2025-10-20 12:59:10	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-20 10:52:20	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-20 06:57:40	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-19 20:04:15	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-19 19:03:43	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-19 15:46:43	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-19 15:34:31	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-19 15:34:22	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-19 13:55:32	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-19 13:20:27	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT
2025-10-19 11:30:21	ALLOWED	TCP	10.10.1.5	198.51.100.55	8080	C2_CONTACT

Figure 20:Command-and-Control (C2) Communications

Security Significance

The repeated communication pattern suggests a compromised host establishing contact with an external command-and-control server.

Indicators supporting this assessment include:

- Consistent outbound communications
- Repeated connections to the same external host
- Firewall classification as C2_CONTACT
- Temporal correlation with web shell activity

Risk Assessment

Critical

Potential malware execution and remote attacker control of the compromised system cannot be ruled out.

6. Findings

Finding 1: Automated Reconnaissance and Scanning Activity

Risk Rating: Medium

Description

Analysis of web traffic logs identified extensive reconnaissance activity originating from IP address 198.51.100.55. Requests were generated using automated tools including curl, wget, zgrab, and Go-http-client. The activity targeted common web resources, backup files, configuration files, and application endpoints in an effort to identify exposed services and potential attack vectors.

Evidence

- Requests targeting /phpinfo.php
- Requests targeting /.env
- Requests targeting /.git/config
- Requests targeting /logs.tar.gz
- User agents: curl, wget, zgrab, Go-http-client

MITRE ATT&CK

- T1595 – Active Scanning

- T1592 – Gather Victim Host Information

Finding 2: SQL Injection Attack Attempts

Risk Rating: High

Description

The investigation identified numerous requests containing SQL injection payloads generated by automated attack tools including SQLMap and Havij. Requests targeted parameters within application pages such as item.php and search.php, utilizing time-based SQL injection techniques involving the SLEEP() function.

Evidence

```
/item.php?id=1 AND SLEEP(5)--  
/search.php?q=test'%20AND%20SLEEP(5)--
```

User Agents:

```
sqlmap/1.7.9  
Havij/1.17
```

HTTP responses included 200, 500, and 504 status codes, indicating the application processed multiple malicious requests.

Impact

Successful exploitation could allow attackers to access, modify, or exfiltrate database information.

MITRE ATT&CK

- T1190 – Exploit Public-Facing Application

Finding 3: Directory Traversal Attempts

Risk Rating: High

Description

Logs revealed attempts to access operating system files through directory traversal payloads. The attacker attempted to retrieve sensitive files by manipulating file path parameters.

Evidence

/download?file=../../etc/passwd

Impact

Successful exploitation could expose sensitive operating system files, user accounts, and configuration information.

MITRE ATT&CK

- T1190 – Exploit Public-Facing Application
- T1005 – Data from Local System

Path	Attack Type	OWASP Top 10
/item.php?id=1 AND SLEEP(5)--	SQL Injection	A03:2021 – Injection
/download?file=../../etc/passwd	Directory Traversal / File Disclosure	A01:2021 – Broken Access Control

Finding 4: Sensitive Resource Enumeration

Risk Rating: High

Description

Multiple requests targeted sensitive application resources commonly associated with misconfigurations or exposed development environments. These requests indicate efforts to identify configuration information and potential credentials.

Evidence

/.env
 /.git/config
 /phpinfo.php
 /logs.tar.gz

Impact

Exposure of these files could reveal credentials, API keys, source code, environment variables, and application configuration details.

MITRE ATT&CK

- T1592 – Gather Victim Host Information

- T1005 – Data from Local System

Finding 5: Web Shell Activity and Remote Command Execution

Risk Rating: Critical

Description

Analysis identified requests targeting a web shell endpoint capable of executing operating system commands. Commands observed in the logs included system identification, permission modification, and execution of external binaries.

Evidence

```
/shell.php?cmd=whoami  
/shell.php?cmd=chmod+x+bunnylock.bin  
/shell.php?cmd=./bunnylock.bin
```

Associated User Agents:

```
Ruby/2.7.0 (Webshell Runner)  
python-requests
```

Impact

This activity indicates probable post-exploitation behavior and suggests that an attacker may have gained the ability to execute arbitrary commands on the target server.

MITRE ATT&CK

- T1059 – Command and Scripting Interpreter
- T1204 – User Execution

Finding 6: Suspected Command-and-Control Communications

Risk Rating: Critical

Description

Firewall logs identified repeated outbound TCP communications from internal host 10.10.1.5 to external IP address 198.51.100.55 over port 8080. The events were categorized as C2_CONTACT, indicating potential communication with attacker-controlled infrastructure.

Evidence

- Source IP: 10.10.1.5
- Destination IP: 198.51.100.55
- Port: 8080
- Reason: C2_CONTACT

Impact

This behavior is consistent with command-and-control communications used by attackers to maintain persistence, issue commands, and receive data from compromised systems.

MITRE ATT&CK

- T1071 – Application Layer Protocol
- TA0011 – Command and Control

7. MITRE ATT&CK Mapping

Observed Activity	MITRE ATT&CK Technique	Technique ID
Automated scanning using curl, wget, zgrab, Go-http-client	Active Scanning	T1595
Requests for .env, .git/config, phpinfo.php, backup files	Gather Victim Host Information	T1592
SQL Injection attempts using SQLMap and Havij	Exploit Public-Facing Application	T1190
Directory Traversal (../../etc/passwd)	Exploit Public-Facing Application	T1190
Accessing backup files and logs archives	Data from Local System	T1005
Web shell execution (shell.php?cmd=whoami)	Command and Scripting Interpreter	T1059
Web shell deployment and execution of bunnylock.bin	User Execution / Malware Execution	T1204
Outbound communication to attacker IP on port 8080	Application Layer Protocol	T1071
Command-and-Control communication	Command and Control	TA0011
Enumeration of web application resources	Active Scanning	T1595

8. Attack Chain Analysis

Analysis of the web traffic and firewall logs revealed a sequence of events consistent with a multi-stage cyber attack. By correlating indicators across multiple log sources, it was possible to reconstruct the likely attack progression and identify the attacker's objectives and tactics.

Stage 1: Reconnaissance and Enumeration

The attacker initiated the activity by performing reconnaissance against the target web application. Numerous requests were observed from IP address 198.51.100.55 using automated tools including curl, wget, zgrab, and Go-http-client. Requests targeted publicly accessible resources and sensitive files such as:

- /.env
- /.git/config
- /phpinfo.php
- /logs.tar.gz

This activity is consistent with information gathering and attack surface discovery.

MITRE ATT&CK: T1595 – Active Scanning, T1592 – Gather Victim Host Information

Stage 2: Vulnerability Discovery and Exploitation Attempts

Following reconnaissance, the attacker launched application-layer attacks targeting web application parameters. Multiple requests containing SQL injection payloads generated by SQLMap and Havij were identified, including time-based injection techniques utilizing the SLEEP() function.

Examples included:

- /item.php?id=1 AND SLEEP(5)--
- /search.php?q=test'%20AND%20SLEEP(5)--

The activity indicates attempts to identify and exploit SQL injection vulnerabilities within the application.

MITRE ATT&CK: T1190 – Exploit Public-Facing Application

Stage 3: Sensitive File Access Attempts

The attacker attempted to access sensitive files and backup archives that could contain credentials, source code, or configuration information. Requests targeting backup files and application resources suggest efforts to obtain information useful for further exploitation.

Examples included:

- /logs.tar.gz
- /.env
- /.git/config

MITRE ATT&CK: T1005 – Data from Local System

Stage 4: Directory Traversal Activity

Evidence of directory traversal attempts was identified through requests designed to access operating system files outside the intended application directory structure.

Example:

- /download?file=../../etc/passwd

This technique is commonly used to retrieve sensitive system information and validate file disclosure vulnerabilities.

MITRE ATT&CK: T1190 – Exploit Public-Facing Application

Stage 5: Web Shell Execution and Remote Command Execution

Subsequent log analysis revealed requests directed at a web shell endpoint capable of executing operating system commands.

Observed commands included:

- whoami
- chmod +x bunnylock.bin
- ./bunnylock.bin

The execution of system commands indicates that the attacker likely achieved remote code execution and transitioned from exploitation to post-exploitation activities.

MITRE ATT&CK: T1059 – Command and Scripting Interpreter

Stage 6: Payload Deployment and Execution

The attacker deployed and executed a binary named bunnylock.bin. The use of commands to modify file permissions and execute the binary suggests malware deployment or execution of a secondary-stage payload.

This activity represents a significant escalation in attacker capability and indicates potential compromise of the target system.

MITRE ATT&CK: T1204 – User Execution

Stage 7: Command-and-Control Communications

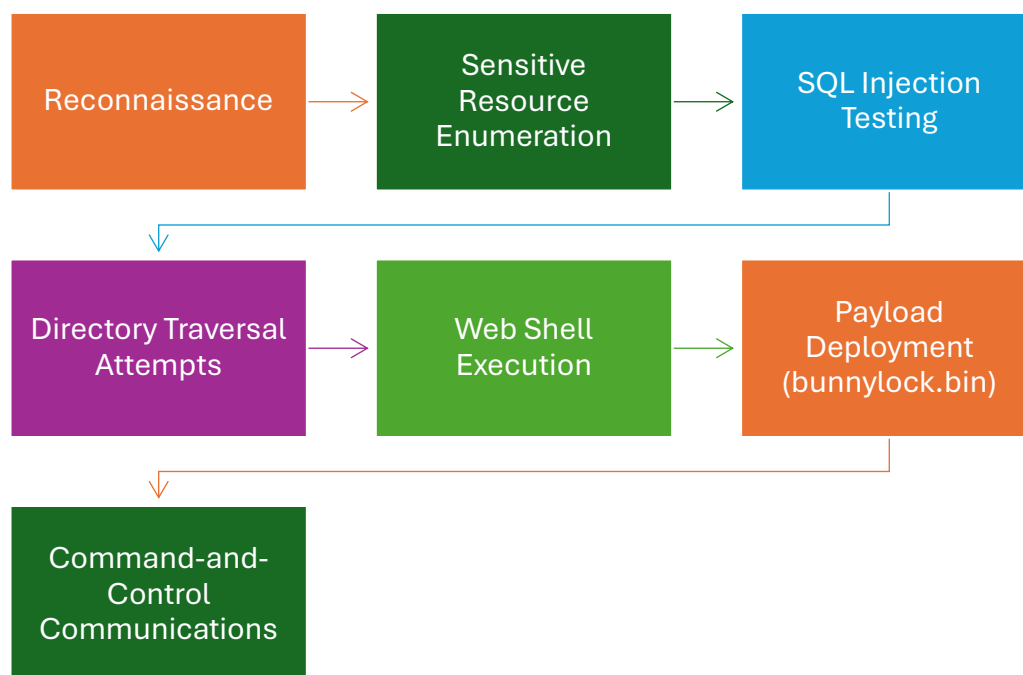
Firewall logs identified repeated outbound communications between internal host 10.10.1.5 and external IP address 198.51.100.55 over TCP port 8080. These connections were categorized as C2_CONTACT and occurred after the observed web shell activity.

The timing and frequency of these communications suggest that the compromised host established contact with attacker-controlled infrastructure for command-and-control purposes.

MITRE ATT&CK: T1071 – Application Layer Protocol

Attack Chain Summary

The correlated evidence suggests the following attack progression:



The sequence of events indicates a likely compromise of the web application environment followed by post-exploitation activity and outbound communication with external attacker infrastructure. The investigation demonstrates how log correlation across web and firewall data sources can be used to reconstruct attacker behavior and identify the stages of a cyber intrusion.

9. Conclusion

The investigation identified multiple indicators of malicious activity within the web application environment, including automated reconnaissance, SQL injection attempts, directory traversal attacks, sensitive resource enumeration, web shell execution, and outbound command-and-control communications. The observed attack chain suggests a progression from reconnaissance and vulnerability probing to post-exploitation activity. The combination of SQLMap and Havij activity, web shell execution, deployment of the bunnylock.bin payload, and subsequent C2 communications provides strong evidence of a likely compromise of the target environment. Immediate containment, forensic investigation, and remediation efforts are recommended to prevent further unauthorized access and potential data loss.

10. Recommendations

Based on the findings of this investigation, the following recommendations are provided to reduce the likelihood of future attacks and strengthen the security posture of the web application environment.

1. Implement Secure Input Validation and Parameterized Queries

The presence of SQL injection payloads indicates attempts to exploit application input fields. All user-supplied input should be validated and sanitized before processing. Developers should utilize parameterized queries or prepared statements to prevent malicious SQL code from being executed.

2. Strengthen Web Application Security Controls

Implement a Web Application Firewall (WAF) to detect and block common attack patterns, including SQL injection, directory traversal, and automated scanning activity. Regularly review WAF logs to identify emerging threats and suspicious behavior.

3. Restrict Access to Sensitive Files and Resources

Configuration files, backup archives, and development resources should not be publicly accessible. Access controls should be implemented to prevent unauthorized access to files such as:

- .env
- .git/config
- phpinfo.php
- Backup archives and log files

Regular security reviews should be performed to identify and remove exposed sensitive resources.

4. Prevent Directory Traversal Vulnerabilities

Applications should validate file paths and restrict user access to approved directories. Input validation and file access controls should be implemented to prevent unauthorized access to operating system files and sensitive application resources.

5. Detect and Prevent Web Shell Activity

Organizations should implement file integrity monitoring and endpoint detection capabilities to identify unauthorized scripts and web shells. Suspicious command execution activity should generate alerts for immediate investigation.

6. Strengthen Endpoint Monitoring and Malware Detection

The execution of suspicious binaries indicates potential malware deployment. Endpoint Detection and Response (EDR) solutions should be deployed to monitor process execution, detect malicious behavior, and support rapid incident response activities.

7. Monitor and Block Command-and-Control Communications

Network monitoring controls should be implemented to identify unusual outbound communications. Firewall rules and intrusion detection systems should be configured to detect and block connections to known malicious infrastructure and suspicious external destinations.

8. Enhance Security Monitoring and Threat Detection

Security teams should continuously monitor web server, firewall, and application logs using SIEM technologies such as Splunk. Detection rules should be developed for:

- SQL injection attempts
- Directory traversal attacks
- Web shell activity
- Suspicious user-agent strings
- Command-and-control communications

9. Conduct Regular Vulnerability Assessments and Penetration Testing

Periodic vulnerability assessments and penetration tests should be performed to identify security weaknesses before they can be exploited by attackers. Findings should be tracked and remediated through a formal vulnerability management process.

10. Implement Incident Response Procedures

Organizations should maintain an incident response plan that includes procedures for identifying, containing, eradicating, and recovering from web application compromises. Security teams should regularly test and update response procedures to ensure readiness during security incidents.

11. Skills Demonstrated

Security Operations & Threat Hunting

- Threat Hunting
- Security Event Analysis
- Log Correlation
- Indicator of Compromise (IOC) Identification
- Attack Chain Reconstruction

SIEM & Log Analysis

- Splunk Enterprise
- SPL Query Development
- Event Investigation
- Web Traffic Analysis
- Firewall Log Analysis

Threat Detection

- SQL Injection Detection
- Directory Traversal Detection
- Web Shell Activity Identification
- Command-and-Control Detection
- Suspicious User-Agent Analysis

Cybersecurity Frameworks

- MITRE ATT&CK Mapping
- Incident Investigation Methodology
- Risk Assessment
- Security Reporting

Analytical Skills

- Root Cause Analysis

- Evidence-Based Investigation
- Security Documentation
- Technical Communication

References

- 1) TryHackMe. "Splunk for Log Analysis – Advent of Cyber 2025." *TryHackMe*, <https://tryhackme.com/room/splunkforloganalysis-aoc2025-x8fj2k4rqp>. Accessed 10 May 2026.
- 2) Splunk Inc. Splunk Enterprise Documentation. Splunk Documentation, <https://docs.splunk.com/Documentation>. Accessed 10 May 2026.
- 3) MITRE ATT&CK. *Enterprise ATT&CK Matrix*. MITRE Corporation, <https://attack.mitre.org/>. Accessed 10 May 2026.
- 4) OWASP Foundation. *OWASP Top 10: The Ten Most Critical Web Application Security Risks*. OWASP Foundation, <https://owasp.org/www-project-top-ten/>. Accessed 10 May 2026.
- 5) OWASP Foundation. *Web Security Testing Guide (WSTG)*. OWASP Foundation, <https://owasp.org/www-project-web-security-testing-guide/>. Accessed 10 May 2026.